

INFORMATION SECURITY & DATA SECURITY

1. What is Information Security?

Information Security (InfoSec) means protecting important information from people who should not access, change, use, or destroy it. The main goal is to make sure that only the right people can see and use sensitive data.

Organizations protect many types of information assets, including:

- **Financial data** (bank records, transactions)
- **Confidential business data** (trade secrets, plans)
- **Personal data** of customers or employees
- **Sensitive data in digital files, paper documents, physical media, or even spoken words**

Today, organizations use both local servers and cloud systems (called hybrid or multi-cloud environments). This makes security more complex. Cyber threats are also growing. To handle this, different teams — **IT, security, and management** — must work together and regularly update their tools and policies.

2. Types of Security

Information Security is a broad term that covers many different types of security. The main types are:

Type	Description
Information Security (InfoSec)	The broadest type. It covers all efforts to protect information, including physical files, digital data, hardware, and software.

IT Security	Focuses on protecting physical and digital technology assets such as servers and data centers. It does not cover paper files.
Cybersecurity	A part of InfoSec. It deals only with computers, networks, software, and digital data. It does not cover physical or paper-based information.
Data Security	Focuses on protecting digital data throughout its entire life. It includes hardware protection, software controls, and organizational policies.

3. The CIA Triad

The CIA Triad is the most important model in information security. It was first suggested by NIST (National Institute of Standards and Technology) in 1977. It has three main principles:

3.1 Confidentiality

Confidentiality means that only authorized people can see certain data. It controls who has access to information.

There are three types of users:

- **Privileged Users:** Can access most company data (e.g., system administrator)
- **Limited Users:** Can only access specific data relevant to their work
- **Public Users:** Can only access data that is available to everyone

Example

A student cannot see another student's grades. Only authorized staff can access confidential reports.

3.2 Integrity

Integrity means that data must be accurate and must not be changed without proper permission. It ensures that information stays correct and trustworthy.

Integrity protects against:

- **Malicious users (attackers):** who intentionally change or delete data
- **Authorized users:** who may accidentally modify data in the wrong way

Example

A bank account balance should only change when a real and valid transaction is made. No unauthorized changes should be possible.

3.3 Availability

Availability means that authorized users can access the data they need, whenever they need it. Security measures must not block authorized users from doing their work.

Example

A hospital system must be available 24 hours a day. If doctors cannot access patient records during an emergency, it can be dangerous.

3.4 Nonrepudiation

Nonrepudiation means that a person cannot deny doing something they have actually done. If a user sends a message or approves a transaction, the system records it with proof so they cannot later say it was not them.

Example

A manager approves a fund transfer using their unique ID and password. The system records this with a digital signature and timestamp. Later, the manager cannot claim they did not approve it.

3.5 Authentication

Authentication is the process of checking who a person is before giving them access. It answers the question: Are you really who you say you are?

Authentication is usually based on one or more of these factors:

- **Something you know:** Password or PIN
- **Something you have:** ID card, phone, or security token
- **Something you are:** Fingerprint or face recognition (biometrics)

Example

A student logs into a university portal by entering their student ID (something they know), then confirming with a one-time code sent to their phone (something they have).

3.6 Information Assurance

Information Assurance is the ongoing process of making sure that confidentiality, integrity, and availability are maintained at all times inside an information system. It is not a one-time task but a continuous effort.

4. Information Security Programs

An Information Security Program is a formal and structured plan that contains policies, rules, and controls to protect an organization's information. It is built around the CIA Triad.

The key parts of an Information Security Program are:

Component	Description
Risk Management	Identify, assess, and manage risks. Example: conduct regular vulnerability checks.
Security Policies and Procedures	Written rules for how information must be handled. Example: password policy, acceptable use policy.
Access Control	Only authorized users can access specific data. Example: role-based access control (RBAC).
Authentication and Authorization	Verify identity and grant the right level of access. Example: two-factor authentication (2FA).
Incident Response Plan	Steps to follow when a security breach occurs. Example: procedure for handling ransomware.
Security Awareness Training	Educate employees about threats like phishing. Example: annual cybersecurity training.
Data Encryption and Protection	Encrypt sensitive data so only authorized people can read it. Example: encrypt customer data in databases.
Monitoring and Auditing	Watch systems and review logs regularly to detect suspicious activity.
Compliance and Legal Requirements	Follow laws like GDPR and standards like ISO/IEC 27001. Example: align data privacy practices with legal rules.

5. Risk Management in Information Security

Risk Assessment is the process of identifying, analyzing, and evaluating possible threats and weaknesses that could harm an organization's systems or data. It is a core part of any InfoSec program.

5.1 Objectives of Risk Assessment

1. Identify threats (e.g., cyberattacks, hardware failures)
1. Recognize vulnerabilities (e.g., weak passwords, outdated software)
2. Evaluate the possible impact and how likely each risk is
3. Prioritize risks based on their seriousness
4. Recommend controls or solutions to reduce risks

5.2 Steps in Risk Assessment

Step	Description
Step 1: Identify Assets	List all important assets. Example: customer data, servers, software systems.
Step 2: Identify Threats	List possible threats. Example: malware, insider threats, natural disasters.
Step 3: Identify Vulnerabilities	Find weaknesses. Example: unpatched systems, untrained users.
Step 4: Assess Impact and Likelihood	Rate each risk by how severe and how likely it is to happen.
Step 5: Determine Risk Level	Use a risk matrix to label risks as Low, Medium, or High.
Step 6: Recommend Controls	Suggest solutions. Example: install firewalls, train users, do regular backups.

5.3 Sample Risk Matrix

Asset	Threat	Vulnerability	Impact	Likelihood	Risk Level
Customer Data	Phishing Attack	Lack of user training	High	High	HIGH
Web Server	DDoS Attack	No traffic monitoring	High	Medium	MEDIUM

5.4 Identifying Threats

A threat is anything that could harm the confidentiality, integrity, or availability of an information system. Threats can be:

- **Cyber threats:** Attacks that exploit digital weaknesses. Example: a Denial of Service (DoS) attack floods a system with traffic to crash it.
- **Physical threats:** Natural disasters, hardware failure, physical or armed attacks on facilities.

5.5 Identifying Vulnerabilities

A vulnerability is a weakness in an IT system that an attacker can exploit to get unauthorized access. Vulnerabilities can exist in software code (bugs), system configuration, or human behavior (e.g., falling for phishing emails).

5.6 Incident Response Planning

An Incident Response Plan (IRP) is a set of instructions an organization follows when a security incident is detected. It is created by a Computer Security Incident Response Team (CSIRT), which may include the CISO, IT staff, legal teams, and management.

Common steps in an IRP:

- Assemble the security team (virtually or in person)
- Verify the source of the threat
- Take action to contain and stop the threat as quickly as possible
- Determine what damage, if any, has been caused
- Notify relevant people inside and outside the organization

6. Tools in Information Security

The following tools are commonly used to protect information systems:

Tool	Purpose and Example
Antivirus / Anti-malware	Detects and removes viruses, worms, and other malicious programs. Example: Windows Defender, Bitdefender.
Firewalls	Monitors and controls network traffic based on security rules. Example: pfSense, Cisco ASA.
IDS / IPS	Intrusion Detection System detects unauthorized access; Intrusion Prevention System blocks it. Example: Snort, Suricata.
Encryption Tools	Converts readable data into unreadable code to prevent unauthorized access. Example: VeraCrypt, BitLocker.
Password Managers	Stores and generates strong passwords securely. Example: LastPass, Bitwarden.
VPN (Virtual Private Network)	Creates a secure, encrypted tunnel over the internet. Example: NordVPN, OpenVPN.
SIEM (Security Info & Event Mgmt)	Collects and analyzes security logs from many sources to detect threats. Example: Splunk, IBM QRadar.
MFA (Multi-Factor Authentication)	Requires more than one step to verify identity (e.g., OTP, biometric). Example: Google Authenticator.

7. Techniques to Establish Information Security

Technique	What It Does
-----------	--------------

Access Control	Limits who can access systems and data based on user roles and permissions.
Data Backup and Recovery	Regularly saves copies of data so it can be restored after a loss or attack.
Patch Management	Keeps all software up to date to fix known vulnerabilities.
Security Awareness Training	Teaches employees how to recognize and avoid threats like phishing.
Penetration Testing (Ethical Hacking)	A security expert simulates an attack to find weaknesses before real attackers do.
Network Segmentation	Divides a large network into smaller sections to limit damage from an attack.
Audit and Monitoring	Continuously reviews system logs and activities to detect unusual behavior.

8. Threats in Information Security

Threat Type	Description
Cyberattacks	Attacks such as malware, phishing, ransomware, DDoS, and APTs (Advanced Persistent Threats). These try to steal or damage data.
Employee Error	Staff may lose devices with sensitive data, click on dangerous links, or use weak passwords.
Ineffective Endpoint Security	Any laptop, phone, or PC without proper antivirus becomes an entry point for attackers.
Malicious Insiders	Employees, partners, or authorized users who intentionally cause harm for personal gain.
Negligent Insiders	Authorized users who accidentally cause security problems by not following rules.
Misconfigurations	Incorrect setup of cloud storage, software, or web applications that create security gaps.
Social Engineering	Tricks used to manipulate employees into revealing passwords or sensitive information (e.g., fake phone calls or emails).

9. Benefits of Information Security

Benefit	Explanation
---------	-------------

Business Continuity	Important data can be protected and restored after a security incident.
Compliance	Helps organizations follow laws like HIPAA and PCI-DSS, avoiding fines.
Cost Savings	Proper security reduces the risk of expensive breaches and avoids overspending on unnecessary security.
Greater Efficiency	When data is clearly labeled and processes are secure, employees can work more effectively.
Reputation Protection	Avoiding breaches protects the organization's public image and customer trust.
Risk Reduction	Incident response plans and security controls reduce the chance and impact of attacks.
Authentication Protection	Protects sensitive financial data and trade secrets from unauthorized access.
Disaster Recovery	Ready-made recovery plans allow faster recovery from security incidents.

10. Challenges of Information Security

Challenge	Explanation
Complacency	After setting up a security system, organizations may relax. But threats keep evolving, so constant updates are needed.
Complexity	Modern systems including IoT and mobile devices are complex and require expert teams to manage.
Time Drain	Constantly reconfiguring and maintaining security systems takes a lot of time and resources.
Global Connections	Different countries have different systems and rules, making secure international data sharing difficult.
Inflexibility	Too much security can block normal business activities. A balance must be found.
Third-Party Integration	Connecting with external vendors or partners may introduce new security risks.

11. What is Data Security?

Data security is the practice of protecting digital information from unauthorized access, corruption, or theft throughout its entire lifecycle. It is part of the broader concept of Information Security.

Data security covers:

- Physical protection of hardware and storage devices
- Administrative controls (who can manage the system)
- Access controls (who can read or modify the data)
 - Logical security of software applications
 - Organizational policies and procedures

When done properly, data security protects against cybercriminal attacks, insider threats, and human error — which are the most common causes of data breaches.

12. Business Challenges in Data Security (Bangladesh Context)

Bangladesh is undergoing rapid digital transformation. This brings new data security challenges for organizations:

Challenge	Details
Growing data volume	Organizations generate and store more data than ever, increasing risk.
Complex environments	Many businesses use a mix of local servers, cloud platforms, mobile, and IoT devices.
Rising consumer awareness	Customers are increasingly aware of their data privacy rights.
Regulatory requirements	Organizations must follow the Digital Security Act (DSA) 2018, and guidelines from Bangladesh Bank and BTRC.
Risk of non-compliance	Not following these regulations can result in financial penalties and reputational damage.
Business data loss	Loss of trade secrets or intellectual property can harm innovation and competitiveness.

13. Types of Data Security

Type	Description
------	-------------

Encryption	An algorithm is used to convert readable data into unreadable code. Only authorized users with the right key can read it. Encryption tools also include key management features.
Data Erasure	Software completely overwrites data on a storage device so it cannot be recovered. More secure than simple deletion.
Data Masking	Sensitive data is hidden or replaced with fake data so developers can build or test applications without exposing real information.
Data Resiliency	The ability of an organization to recover from failures (hardware problems, power outages, etc.) with minimal data loss or downtime.

14. Data Security Capabilities and Tools

Modern data security tools help organizations manage and protect data in complex, multi-cloud, and distributed environments.

Tool / Capability	What It Does
Data Discovery and Classification	Automatically finds and labels sensitive data in databases, cloud storage, and other repositories.
Data and File Activity Monitoring	Tracks who is accessing data and when. Detects unusual access patterns and sends alerts.
Vulnerability Assessment Tools	Identifies weaknesses like outdated software, wrong configurations, and weak passwords.
Automated Compliance Reporting	Generates audit reports automatically to prove compliance with regulations like GDPR.
Data Security Posture Management (DSPM)	Continuously monitors data security in real time. Finds hidden data, identifies risks, and helps teams focus on fixing problems.

15. Strategies in Data Security

A strong data security strategy involves people, processes, and technology. It must be a priority at all levels of the organization.

Strategy Area	Description
Physical Security of Servers and Devices	Secure server rooms and facilities against unauthorized entry. Have fire suppression and climate controls in place. Cloud providers handle this for cloud-hosted data.

Access Management and Controls	Follow the principle of least-privilege access: give access only to those who truly need it. Limit admin and database access.
Application Security and Patching	Always update software to the latest version as soon as new patches or versions are released.
Backups	Keep usable and regularly tested backup copies of all critical data. Apply the same security rules to backups as to the main systems.
Employee Education	Train employees to understand security best practices, password hygiene, and how to recognize social engineering attacks.
Network and Endpoint Security	Use a comprehensive set of threat management, detection, and response tools across both on-premises and cloud environments.

16. Data Security Trends in Bangladesh

Trend	What It Means
Artificial Intelligence (AI)	AI helps organizations detect unusual activities and cyber threats quickly. It can make fast decisions during security incidents. This is especially useful in banking, telecom, and e-commerce in Bangladesh.
Multicloud Security	Many organizations in Bangladesh now use both local servers and cloud platforms. Security must protect data, applications, and business processes across all cloud environments.
Quantum Technology	Quantum computing is still in early stages but will lead to stronger encryption methods in the future. Organizations should prepare now for these changes to protect long-term data security.

17. How Data Security Interacts with Other Security Areas

17.1 Achieving Enterprise-Grade Data Security

Data security works closely with all other areas of security. A good approach is risk-based:

1. Understand the organization's business goals and legal requirements.
2. Identify the most sensitive data (customer data, financial records, etc.).
3. Start security measures with the most important data first.
4. Gradually apply policies to all other data.

5. Use automated tools to monitor and protect data across the entire system.

17.2 Data Security and the Cloud

Cloud environments require a different security approach than traditional systems. In the past, organizations focused on protecting the network boundary. Now, data lives in the cloud, so security must be more flexible.

Key requirements for cloud data security:

- Tools to identify and classify data stored in the cloud
- Continuous monitoring of user activity and data movement
- Real-time risk management and response
- Consistent security policies regardless of where data is stored

18. Examples of Security Breaches

The following real-world examples show how security breaches happen and their serious consequences:

Incident	Data Compromised	Key Consequences
Equifax (2017)	147 million people's SSNs, birth dates, addresses	\$700M+ in fines; executives resigned; focus on patch management increased
Yahoo (2013-14)	All 3 billion accounts: names, emails, passwords	\$350M deduction in acquisition price; massive loss of user trust
Target (2013)	40M credit/debit cards; 70M customers' personal info	\$162M in costs; lawsuits; highlighted vendor security risks
Bangladesh Bank (2016)	\$81 million stolen via SWIFT transfer fraud	Global focus on SWIFT security; major financial and reputational loss
Sony Pictures (2014)	Unreleased films, employee emails, business data	Millions in financial loss; reputational damage; intellectual property harm
Cambridge Analytica (2018)	87 million Facebook users' profile data without consent	\$5 billion FTC fine; GDPR enforcement; Facebook changed data policies
Facebook DB Leak (2019)	Hundreds of millions of phone numbers, names, IDs	Risk of SIM swapping and phishing; Facebook limited API phone access
Google+ Exposure (2018)	500,000+ accounts: names, emails, ages, occupations	Google+ shut down early; damaged trust due to delayed disclosure
Android App Permissions	Location data, device IDs collected without clear consent	EUR 50M GDPR fine in France; Google introduced stricter app policies

Key Lesson

Most major breaches happened because of unpatched software, weak credentials, third-party vulnerabilities, or lack of proper access control.

Organizations must take proactive steps rather than waiting for an attack to happen.

End of Notes

Review all sections carefully before your exam. Focus on definitions, the CIA Triad, tools, threats, and breach examples.